

Sécurisation :

```

<?php
// transfer.php
session_start();

// Génération du token CSRF
if (empty($_SESSION['csrf_token'])) {
    $_SESSION['csrf_token'] = bin2hex(random_bytes(32));
}

// Vérification de la connexion
if (!isset($_SESSION['user'])) {
    header('Location: login.php');
    exit;
}

$message = '';

if ($_SERVER['REQUEST_METHOD'] === 'POST') {
    // Vérification du token CSRF
    if (
        !isset($_POST['csrf_token']) ||
        $_POST['csrf_token'] !== $_SESSION['csrf_token']
    ) {
        die("CSRF détectée !");
    }

    // Récupération des données
    $amount = $_POST['amount'] ?? '';
    $recipient = $_POST['recipient'] ?? 'compte-destinataire';

    // Simulation d'une action sensible
    $message = "Transfert de " .
        htmlspecialchars($amount) .
        " € vers " .
        htmlspecialchars($recipient) .
        " effectué par " .
        htmlspecialchars($_SESSION['user']) .
        ".";
}

```

```

9 |         ".";
10 |     }
11 | }
12 | ?>
13 |
14 | <!DOCTYPE html>
15 | <html lang="fr">
16 | <head>
17 |     <meta charset="UTF-8">
18 |     <title>Transfert</title>
19 | </head>
20 | <body>
21 |
22 | <h1>Transférer des fonds (exemple protégé CSRF)</h1>
23 |
24 | <?php if ($message): ?>
25 |     <p style="color:green;"><?php echo $message; ?></p>
26 | <?php endif; ?>
27 |
28 | <form method="POST" action="">
29 |     <!-- Token CSRF -->
30 |     <input type="hidden" name="csrf_token"
31 |         value="<?php echo $_SESSION['csrf_token']; ?>">
32 |
33 |     <label>Montant (€) :</label><br>
34 |     <input type="number" name="amount" min="1" step="1" required><br><br>
35 |
36 |     <label>Destinataire :</label><br>
37 |     <input type="text" name="recipient"
38 |         value="compte-destinataire" required><br><br>
39 |
40 |     <button type="submit">Transférer</button>
41 | </form>
42 |
43 | <p>
44 |     <a href="profile.php">Retour profil</a> |
45 |     <a href="login.php?logout=1">Se déconnecter</a>
46 | </p>
47 |
48 | </body>
49 | </html>
50 |

```